

Lab Report S10 L5

Creazione e Gestione di Gruppi in Windows Server 2022

Active Directory Domain Services — Dominio “Matrix.local”

Autore: Andrea Calabretta
Corso: Master Cybersecurity & Ethical Hacking CS266IT
Istituto: Epicode
Ambiente: Oracle VirtualBox: Windows Server, Windows 10 pro, pfSense
Data: 12 Giugno 2026
Versione: 1.0

Schema Riassuntivo dell'Infrastruttura

Host	Sistema Operativo	Indirizzo IP	Ruolo
MatrixServer	Windows Server 2022	192.168.20.20	Domain Controller (AD DS / DNS)
MATRIX_CLIENT	Windows 10 Pro N	192.168.20.11	Client di dominio / verifica accessi
pfSense	FreeBSD 2.8.1	192.168.20.1 (OPT1)	Firewall / Gateway

Figura 1 — Infrastruttura virtuale del laboratorio (rete interna “meta-net”)

Indice

1. Introduzione	3
2. Concetti e Strumenti Fondamentali	3
2.1 Che cos'è Windows Server	3
2.2 Active Directory Domain Services (AD DS)	3
2.3 Unità Organizzative (OU)	4
2.4 Gruppi di Sicurezza	4
2.5 pfSense	4
3. Predisposizione dell'Infrastruttura di Rete	5
3.1 Configurazione IP del Client Windows 10	6
4. Promozione del Server a Domain Controller	8
4.1 Aggiunta del Client al Dominio	8
5. Creazione delle Unità Organizzative	10
6. Creazione degli Utenti e dei Gruppi	11
6.1 Assegnazione degli Utenti ai Gruppi	12
7. Assegnazione dei Permessi sulle Risorse Condivise	14
7.1 Permessi del Gruppo La_Resistenza	14
7.2 Permessi del Gruppo Le_Macchine	15
7.3 Creazione dei File di Prova	15
8. Verifica del Modello di Accesso	17
8.1 Accesso con l'Account Neo Anderson (La Resistenza)	17
8.2 Accesso con l'Account Agente Smith (Le Macchine)	19
9. Conclusioni	21
Glossario	22

1. Introduzione

Il presente report documenta l'attività di laboratorio svolta nell'ambito del Master in Cybersecurity & Ethical Hacking presso Epicode, avente come obiettivo la creazione e la gestione di gruppi di utenti in un ambiente Windows Server 2022. L'esercizio prevede la creazione di gruppi di sicurezza, l'assegnazione di permessi differenziati su risorse condivise e la verifica pratica del modello di autorizzazione attraverso account di prova.

Per rendere l'attività più coinvolgente e personale, ho scelto di ambientare l'intero laboratorio nell'universo narrativo del film The Matrix (1999) dei fratelli Wachowski, una delle mie pellicole preferite di sempre. La scelta non è puramente estetica: la dicotomia tra gli esseri umani della Resistenza e le Macchine senzienti che controllano la simulazione si presta sorprendentemente bene a illustrare il principio di separazione dei privilegi (separation of duties) e il modello di controllo degli accessi basato sui ruoli (Role-Based Access Control, RBAC), che costituiscono il cuore concettuale di questo esercizio. Da un lato la Resistenza, con accesso limitato e sorvegliato; dall'altro le Macchine, che detengono il controllo totale del sistema. È una metafora narrativa che, nella mia esperienza di studio, mi ha aiutato a interiorizzare meglio concetti altrimenti astratti.

L'infrastruttura di laboratorio è stata ricostruita interamente da zero su Oracle VirtualBox e si compone di tre macchine virtuali: un controller di dominio Windows Server 2022 (MatrixServer), un client Windows 10 Pro N (MATRIX_CLIENT) e un firewall pfSense che funge da gateway della rete interna. Nei capitoli che seguono ogni fase viene documentata in ordine cronologico, accompagnata dagli screenshot prodotti durante l'esecuzione e da una spiegazione dei principali strumenti e concetti coinvolti.

2. Concetti e Strumenti Fondamentali

Prima di entrare nel dettaglio operativo è utile chiarire il ruolo dei principali componenti tecnologici utilizzati nel laboratorio, in modo da rendere il report comprensibile anche a un lettore non specialista e da dimostrare la padronanza dei concetti sottostanti.

2.1 Che cos'è Windows Server

Windows Server è il sistema operativo di Microsoft destinato all'infrastruttura aziendale. A differenza delle edizioni desktop (come Windows 10 o 11), è progettato per erogare servizi di rete centralizzati a un gran numero di utenti e dispositivi: gestione delle identità, condivisione di file, servizi web, virtualizzazione, DNS, DHCP e molto altro. La versione utilizzata in questo laboratorio è Windows Server 2022, l'edizione più recente al momento dell'esercizio. La sua funzione principale, nel nostro caso, è quella di ospitare il servizio Active Directory, diventando così il punto centrale di autenticazione e autorizzazione dell'intero dominio.

2.2 Active Directory Domain Services (AD DS)

Active Directory Domain Services è il servizio di directory di Microsoft: una sorta di "rubrica" centralizzata e gerarchica che memorizza tutte le informazioni relative agli oggetti della rete

— utenti, gruppi, computer, stampanti e risorse condivise. Il server che ospita Active Directory viene chiamato Domain Controller (DC). Quando un utente effettua il login, il Domain Controller verifica le sue credenziali e stabilisce a quali risorse può accedere. Questo modello centralizzato sostituisce la gestione locale delle utenze (un account distinto su ogni macchina) con un'unica identità valida su tutto il dominio, semplificando enormemente l'amministrazione e la sicurezza.

La struttura logica di Active Directory è organizzata in foreste e domini. La foresta è il contenitore di più alto livello e definisce il confine di sicurezza; il dominio è l'unità amministrativa al suo interno. Nel nostro caso, promuovendo MatrixServer a Domain Controller è stata creata contestualmente una nuova foresta con un unico dominio radice, denominato Matrix.local.

2.3 Unità Organizzative (OU)

Un'Unità Organizzativa (Organizational Unit, OU) è un contenitore logico all'interno di un dominio che permette di raggruppare oggetti correlati — tipicamente utenti, gruppi e computer di uno stesso reparto o funzione aziendale. Le OU non sono semplici cartelle estetiche: rappresentano il livello più granulare a cui è possibile delegare l'amministrazione e applicare le Group Policy (criteri di gruppo). In un'organizzazione reale si creano OU per reparti come “Amministrazione”, “Marketing” o “IT”. In questo laboratorio ho creato due OU a tema: Zion, che raccoglie gli umani della Resistenza, e Machine_City, che raccoglie gli agenti delle Macchine.

2.4 Gruppi di Sicurezza

I gruppi di sicurezza sono lo strumento con cui Active Directory assegna i permessi in modo scalabile. Invece di concedere autorizzazioni a ogni singolo utente — operazione ingestibile in organizzazioni di grandi dimensioni — si assegnano i permessi a un gruppo e si rendono membri del gruppo gli utenti interessati. Quando un utente entra o esce da un ruolo, è sufficiente aggiungerlo o rimuoverlo dal gruppo, senza toccare i permessi delle singole risorse. Questo è il principio del Role-Based Access Control. Nel laboratorio sono stati creati due gruppi di sicurezza globali: La_Resistenza e Le_Macchine, ai quali sono stati assegnati permessi opposti sulle rispettive cartelle condivise.

2.5 pfSense

pfSense è una distribuzione firewall/router open source basata su FreeBSD. Nel laboratorio svolge il ruolo di gateway della rete interna e di firewall perimetrale, gestendo l'instradamento del traffico tra le macchine virtuali e l'eventuale uscita verso internet tramite NAT. Le macchine del dominio sono collegate alla sua interfaccia OPT1, configurata sulla sottorete 192.168.20.0/24.

3. Predisposizione dell'Infrastruttura di Rete

La prima fase dell'esercizio ha richiesto la ricostruzione completa dell'infrastruttura di rete. Su pfSense è stata assegnata una nuova interfaccia di rete (OPT1, corrispondente alla scheda em2) destinata a ospitare il dominio Matrix.local, configurata con indirizzo statico 192.168.20.1/24.

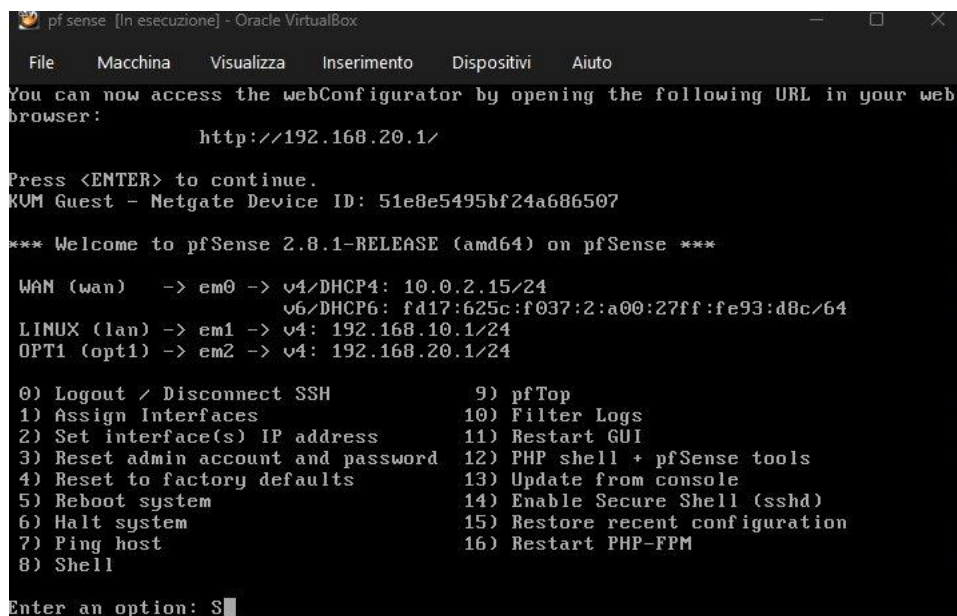


Figura 2 — Configurazione delle interfacce di pfSense: WAN (em0), LAN (em1) e OPT1 (em2, 192.168.20.1)

A livello di VirtualBox, tutte le macchine sono state collegate alla medesima rete interna denominata “meta-net”, in modo da garantire la comunicazione sullo stesso segmento di rete OPT1. La corretta corrispondenza del nome della rete interna tra le diverse VM è un requisito essenziale: un nome differente, anche solo per una lettera, isolerebbe le macchine impedendo ogni comunicazione.

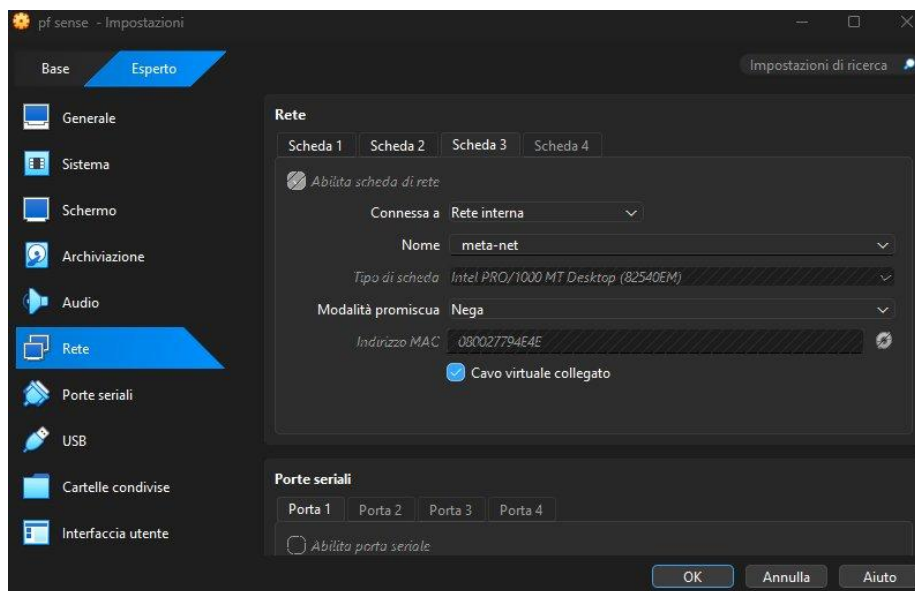


Figura 3 — Scheda di rete di pfSense collegata alla rete interna “meta-net”

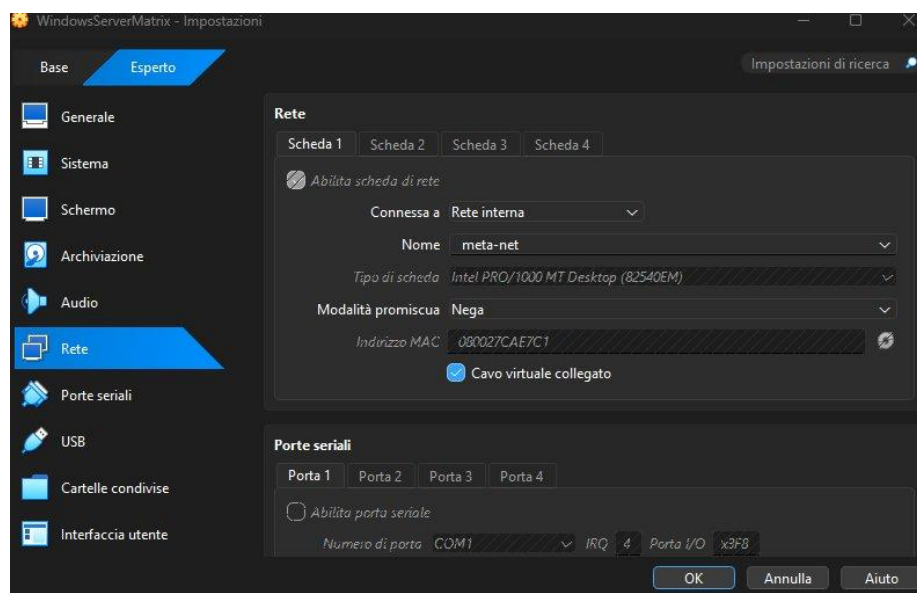


Figura 4 — Scheda di rete del Windows Server collegata alla stessa rete interna “meta-net”

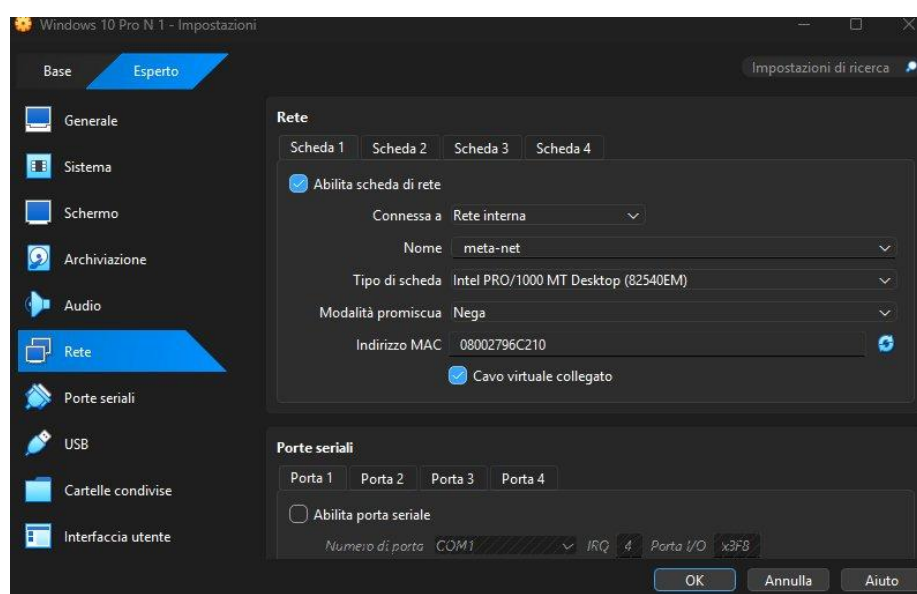


Figura 5 — Scheda di rete del client Windows 10 Pro N collegata alla rete interna “meta-net”

3.1 Configurazione IP del Client Windows 10

Sul client Windows 10 Pro N è stato configurato un indirizzo IP statico coerente con la sottorete OPT1. Un dettaglio cruciale riguarda l'impostazione del server DNS: per poter individuare e raggiungere il dominio Active Directory, il client deve utilizzare come DNS l'indirizzo del Domain Controller (192.168.20.20) e non un DNS pubblico. È il DNS, infatti, a risolvere i record SRV che permettono al client di localizzare i servizi di dominio.

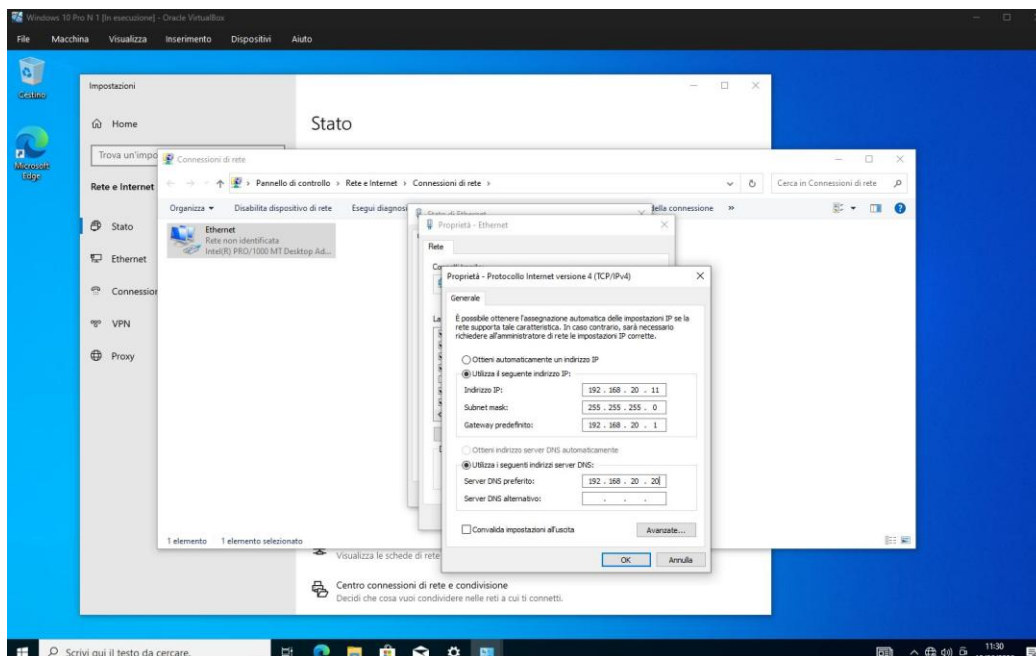


Figura 6 — Configurazione TCP/IPv4 del client: IP 192.168.20.11, gateway 192.168.20.1, DNS 192.168.20.20

4. Promozione del Server a Domain Controller

Una volta stabilita la connettività di rete, il server Windows è stato rinominato in MatrixServer e promosso a Domain Controller mediante l'installazione del ruolo Active Directory Domain Services e la successiva creazione di una nuova foresta con dominio radice Matrix.local. Al termine della procedura, il pannello Server Manager conferma la corretta configurazione: nome computer MatrixServer, dominio Matrix.local, indirizzo IP 192.168.20.20.

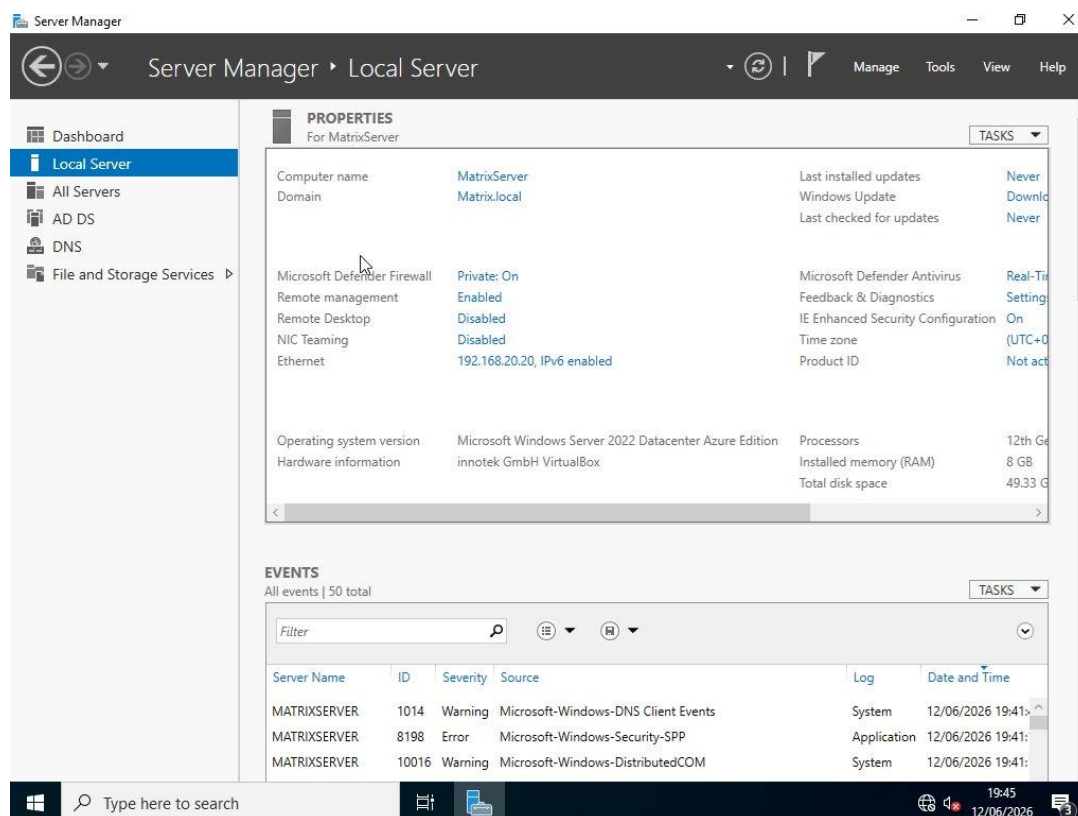
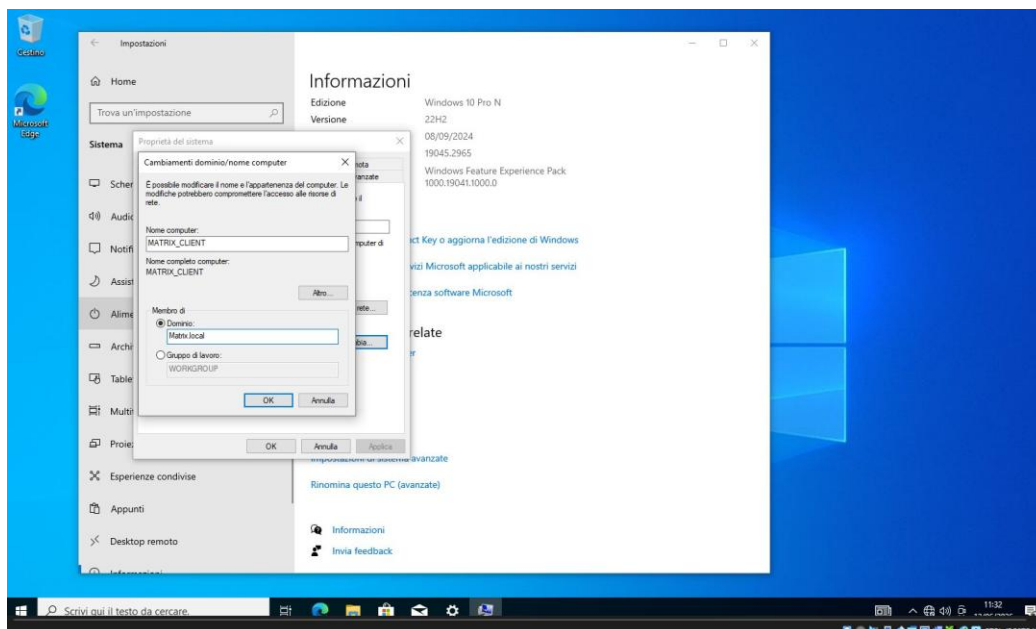


Figura 7 — Server Manager: MatrixServer promosso a Domain Controller del dominio Matrix.local

Va precisato che la foresta non richiede una creazione separata: viene generata automaticamente durante la promozione del primo Domain Controller, quando si seleziona l'opzione di aggiungere una nuova foresta. La struttura risultante è una foresta a dominio singolo, la configurazione più comune nelle piccole e medie organizzazioni.

4.1 Aggiunta del Client al Dominio

Con il dominio attivo, il client Windows 10 Pro N è stato denominato MATRIXUSER e aggiunto al dominio Matrix.local tramite le proprietà di sistema. Questa operazione richiede le credenziali di un amministratore di dominio e, una volta completata, fa sì che il client deleghi al Domain Controller l'autenticazione di tutti gli utenti di dominio.



*Figura 8 — Aggiunta del client MATRIXUSER al dominio Matrix.local
(L'ho cambiato successivamente per problemi di compatibilità con caratteri speciali)*

5. Creazione delle Unità Organizzative

All'interno di Active Directory Users and Computers sono state create due Unità Organizzative a tema. La prima, Zion, prende il nome dall'ultima città libera degli esseri umani nel film: è il contenitore destinato agli account della Resistenza. La seconda, Machine_City, richiama la città delle Macchine e ospita gli account degli agenti.

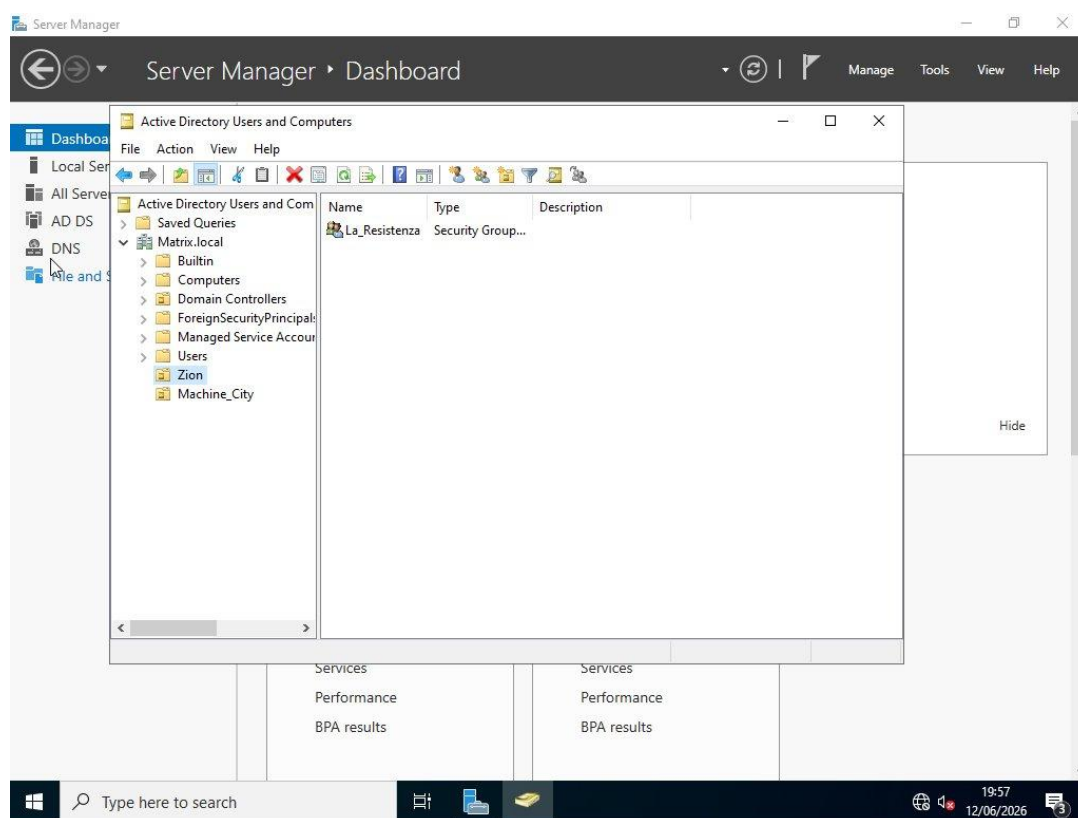


Figura 9 — Creazione dell'Unità Organizzativa "Zion" e del gruppo La_Resistenza

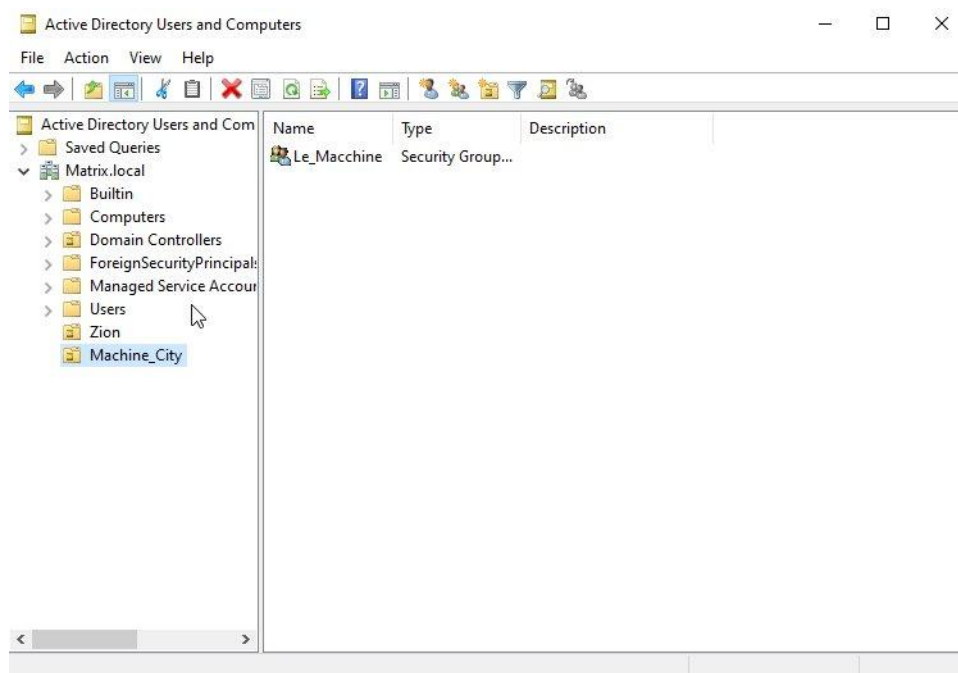


Figura 10 — Creazione dell'Unità Organizzativa "Machine_City" e del gruppo Le_Macchine

6. Creazione degli Utenti e dei Gruppi

All'interno di ciascuna OU sono stati creati gli account utente e il rispettivo gruppo di sicurezza globale. Nella OU Zion sono stati definiti gli account dei tre protagonisti della Resistenza — Neo Anderson, Morpheus e Trinity — insieme al gruppo La_Resistenza. La scelta dei personaggi non è casuale: rappresentano gli utenti “umani” con privilegi limitati, autorizzati alla sola consultazione delle informazioni a loro destinate.

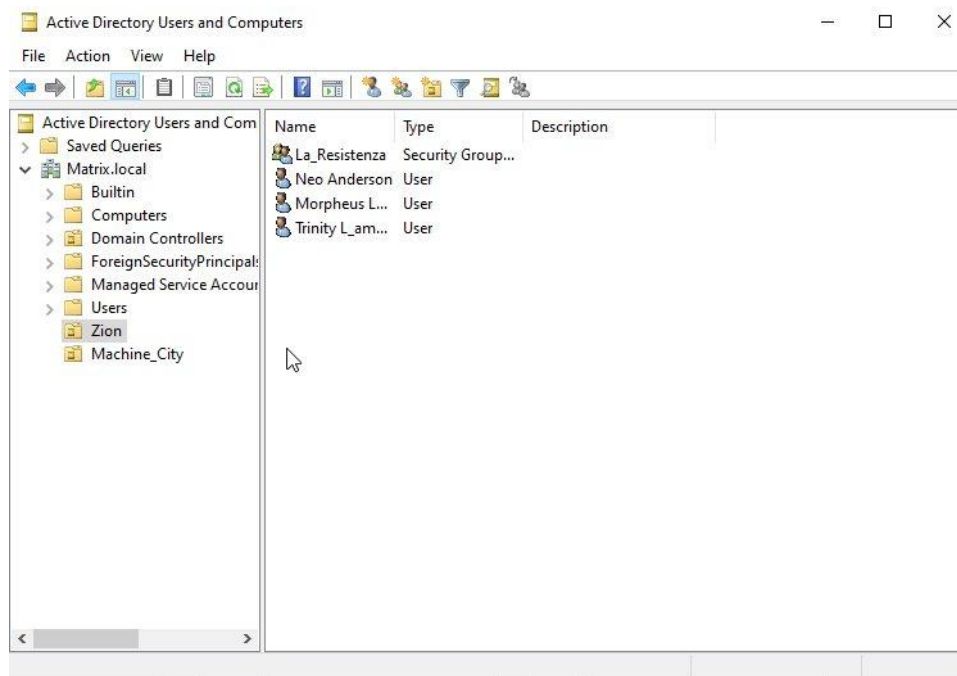


Figura 11 — Utenti Neo Anderson, Morpheus e Trinity nella OU Zion, con il gruppo La_Resistenza

Nella OU Machine_City sono stati creati gli account degli agenti Smith e Jones, insieme al gruppo Le_Macchine. Gli agenti incarnano il ruolo amministrativo del laboratorio: detengono il controllo completo sulle proprie risorse, esattamente come le Macchine controllano la simulazione nel film.

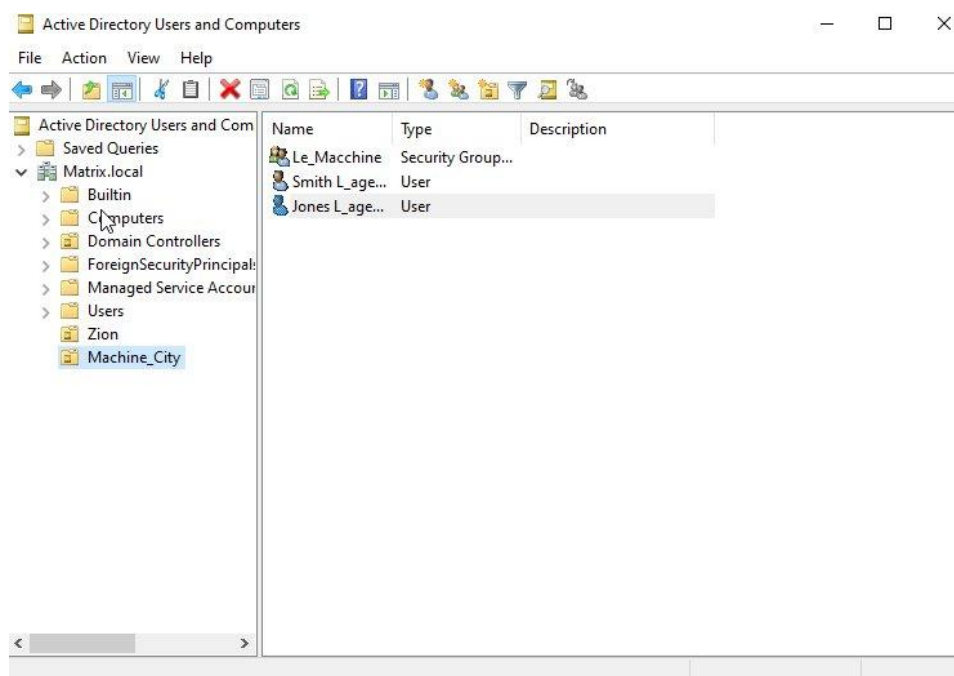


Figura 12 — Utenti Agente Smith e Agente Jones nella OU Machine_City, con il gruppo Le_Macchine

6.1 Assegnazione degli Utenti ai Gruppi

Ogni utente è stato quindi reso membro del gruppo corrispondente al proprio ruolo. Gli account della Resistenza (Neo, Morpheus, Trinity) sono stati aggiunti al gruppo La_Resistenza; gli agenti (Smith, Jones) al gruppo Le_Macchine. Questa associazione è il fulcro del modello RBAC: i permessi non sono legati al singolo utente ma al gruppo, e l'utente li eredita in virtù della propria appartenenza.

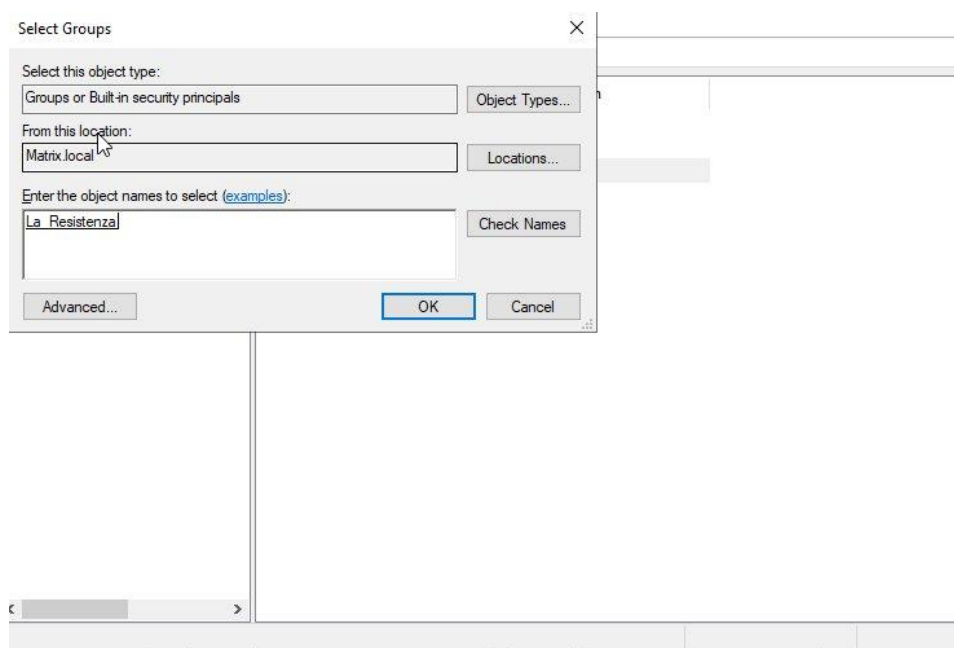


Figura 13 — Aggiunta degli utenti al gruppo La_Resistenza

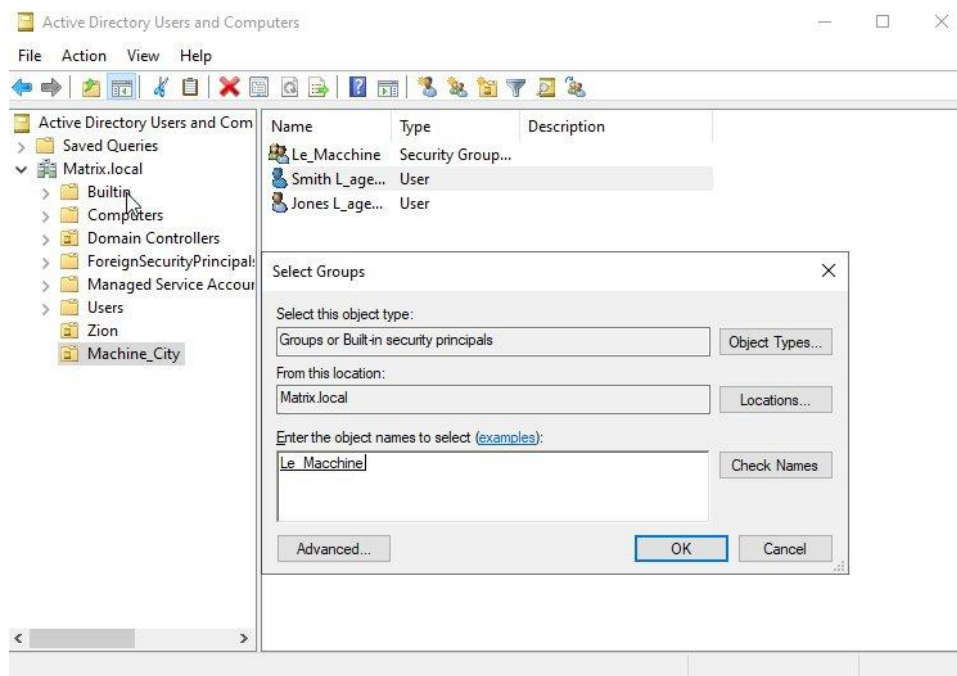


Figura 14 — Aggiunta degli utenti al gruppo Le_Macchine

7. Assegnazione dei Permessi sulle Risorse Condivise

Sul server è stata creata una cartella principale C:\Matrix contenente due sottocartelle condivise, La_Resistenza e Le_Macchine, ciascuna destinata al gruppo omonimo. La differenziazione dei permessi rispecchia la logica narrativa e, soprattutto, illustra concretamente il principio del privilegio minimo (least privilege), secondo cui a ogni soggetto vanno concessi solo i permessi strettamente necessari a svolgere il proprio compito.

7.1 Permessi del Gruppo La_Resistenza

Al gruppo La_Resistenza è stato concesso il solo permesso di lettura (Read) sulla propria cartella. La scelta riflette il fatto che gli umani della Resistenza, nel contesto del laboratorio, devono poter consultare le informazioni operative — messaggi, coordinate, codici di accesso — ma non devono poterle alterare. Dal punto di vista della sicurezza, limitare un gruppo alla sola lettura riduce drasticamente la superficie di rischio: un account compromesso non potrebbe modificare o cancellare i dati.

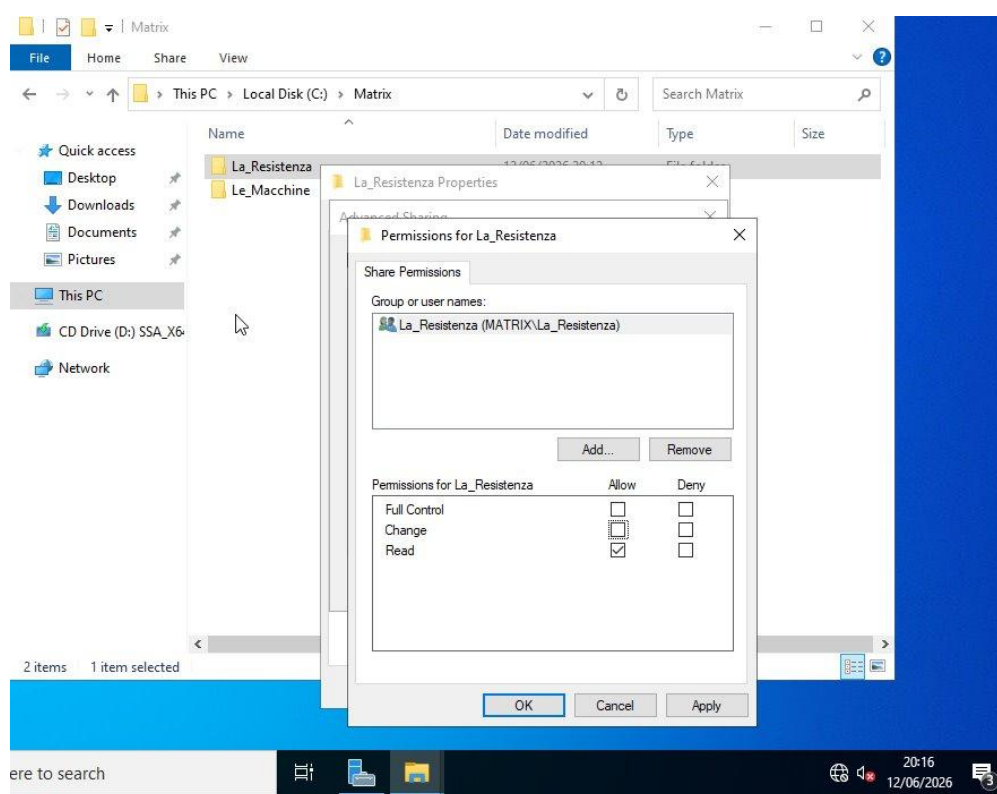


Figura 15 — Permessi di condivisione della cartella La_Resistenza: solo Read (lettura)

7.2 Permessi del Gruppo Le_Macchine

Al gruppo Le_Macchine è stato invece concesso il Controllo Completo (Full Control), che include lettura, scrittura, modifica ed eliminazione. Questo livello di privilegio rispecchia il ruolo dominante delle Macchine e, sul piano tecnico, rappresenta il profilo di un gruppo amministrativo che deve gestire integralmente le proprie risorse. La netta differenza tra i due profili di permesso è esattamente ciò che l'esercizio intende dimostrare.

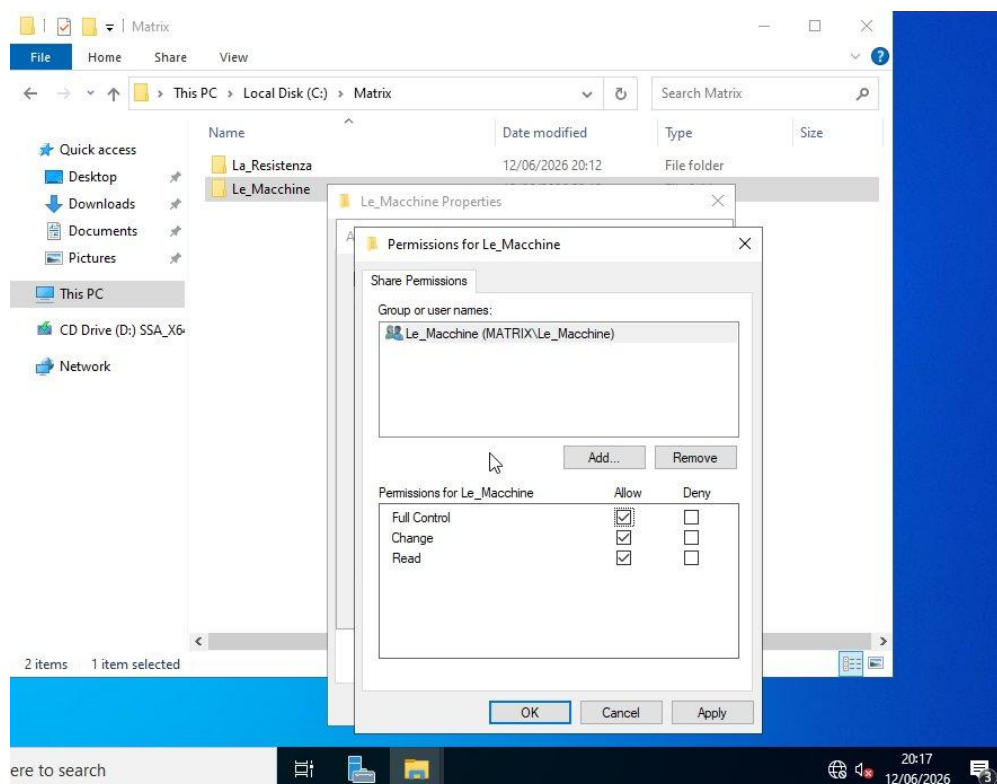


Figura 16 — Permessi di condivisione della cartella Le_Macchine: Full Control (controllo completo)

Gruppo	Permesso	Motivazione
La_Resistenza	Read (sola lettura)	Consultazione delle informazioni senza possibilità di modifica — applicazione del principio del privilegio minimo
Le_Macchine	Full Control	Gestione completa delle risorse — profilo amministrativo con lettura, scrittura, modifica ed eliminazione

Figura 17 — Tabella riepilogativa dei permessi assegnati a ciascun gruppo

7.3 Creazione dei File di Prova

Per rendere verificabile il modello di accesso, in ogni cartella sono stati creati alcuni file di testo a tema. Nella cartella La_Resistenza sono stati inseriti documenti come “Messaggio da Morpheus”, “Coordinate della Nave” e “Codici di Accesso a Zion”. Nella cartella Le_Macchine sono stati creati “Protocolli di controllo”, “Lista anomalie” e “Il codice sorgente”. Si tratta di file fittizi, utili unicamente a testare i permessi.

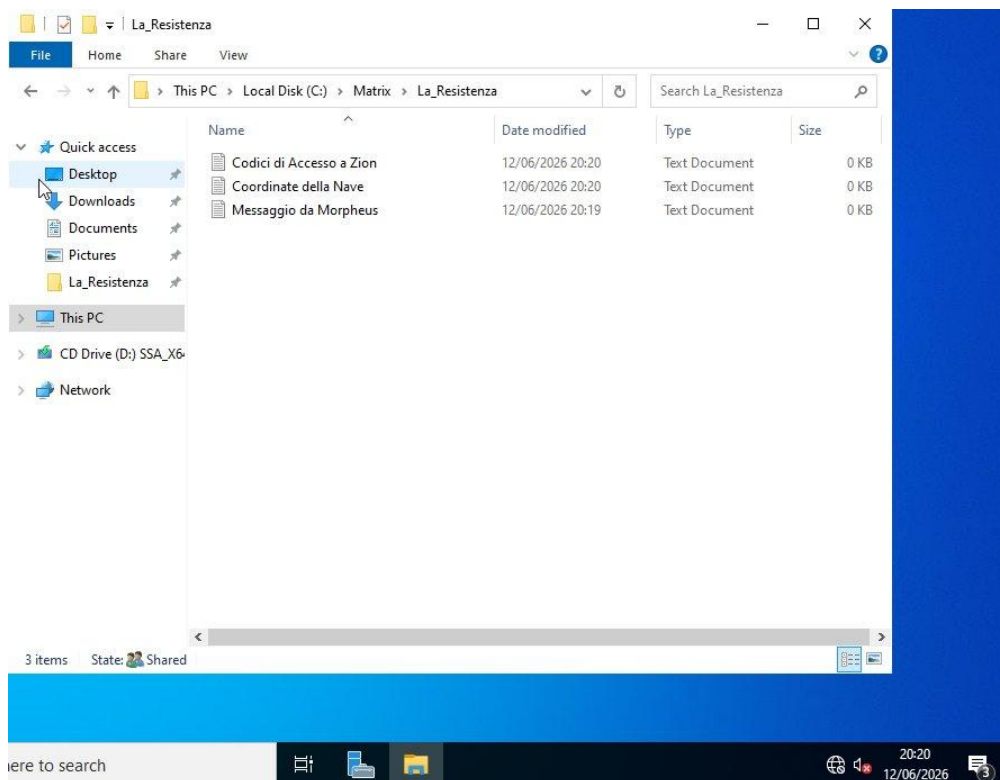


Figura 18 — File di prova creati nella cartella La_Resistenza

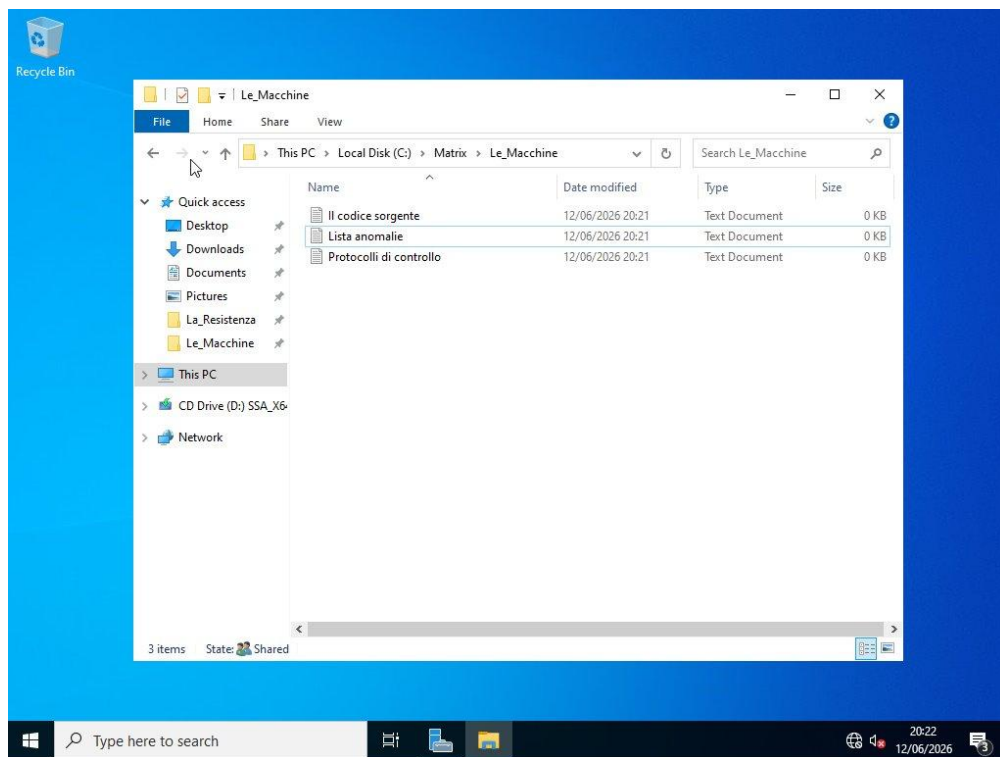


Figura 19 — File di prova creati nella cartella Le_Macchine

8. Verifica del Modello di Accesso

La fase di verifica è il momento in cui si dimostra che i permessi configurati producono il comportamento atteso. Le prove sono state condotte dal client MATRIXUSER effettuando il login con i diversi account di dominio e tentando di accedere a entrambe le cartelle condivise. Un modello RBAC ben configurato deve consentire a ciascun gruppo l'accesso alla propria risorsa e negarlo a quella altrui.

8.1 Accesso con l'Account Neo Anderson (La Resistenza)

Effettuato il login sul client con l'account di dominio Neo Anderson, la rete individua correttamente il Domain Controller MATRIXSERVER e gli altri host del dominio, a conferma del corretto funzionamento della risoluzione DNS e dell'appartenenza al dominio.

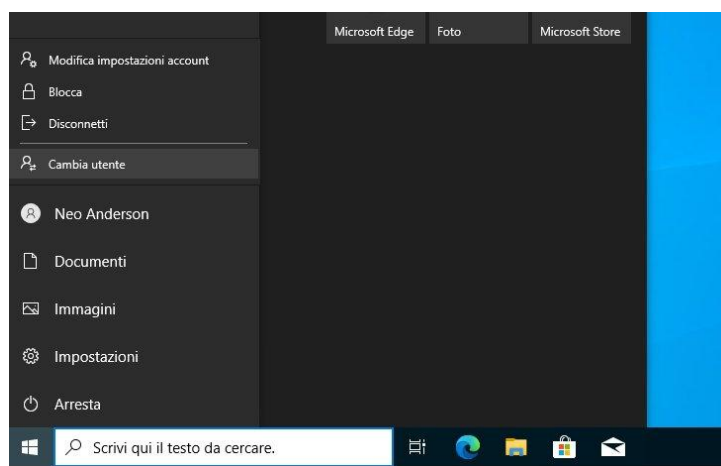


Figura 20 — Login sul client con l'account di dominio Neo Anderson

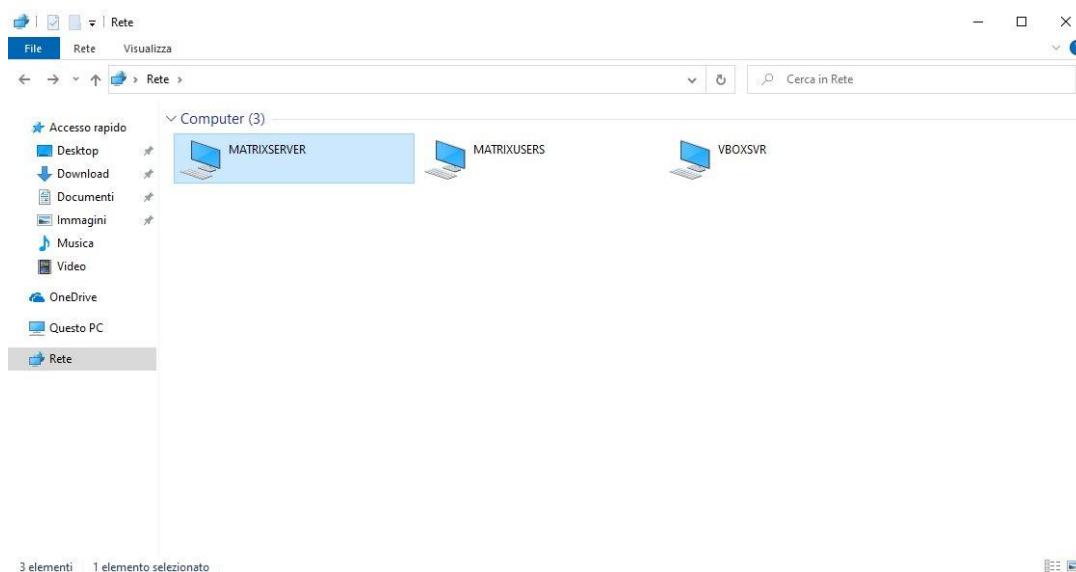


Figura 21 — Esplorazione di rete: il client individua MATRIXSERVER e gli altri host del dominio

Accedendo alla cartella condivisa La_Resistenza, l'utente Neo visualizza correttamente i file destinati al proprio gruppo, in virtù del permesso di lettura assegnato a La_Resistenza.

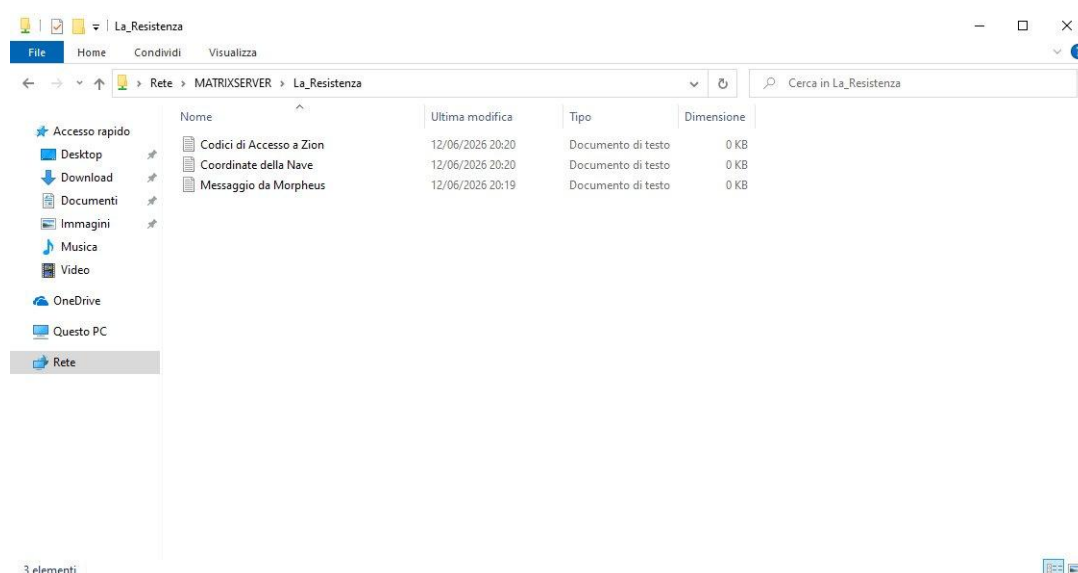


Figura 22 — Neo accede con successo alla cartella La_Resistenza (permesso di lettura)

Al contrario, il tentativo di Neo di accedere alla cartella Le_Macchine viene respinto con un messaggio di “autorizzazioni insufficienti”: l'account non appartiene al gruppo Le_Macchine e quindi non eredita alcun permesso su quella risorsa. È la dimostrazione pratica che la separazione dei privilegi funziona come previsto.

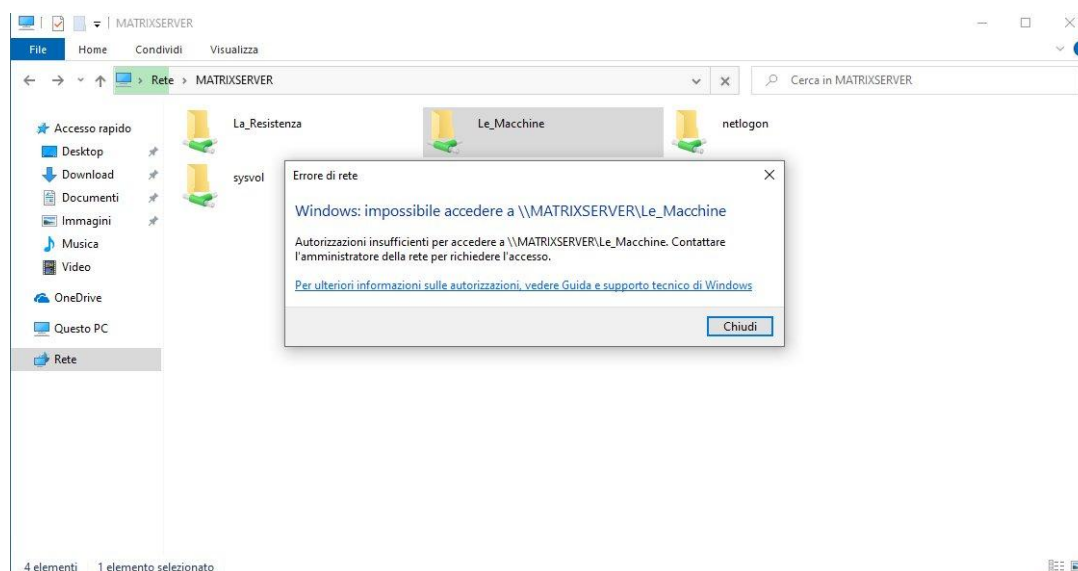


Figura 23 — Accesso negato: Neo non può aprire la cartella Le_Macchine (autorizzazioni insufficienti)

8.2 Accesso con l'Account Agente Smith (Le Macchine)

La stessa verifica è stata ripetuta, in modo speculare, con l'account dell'Agente Smith, membro del gruppo Le_Macchine.

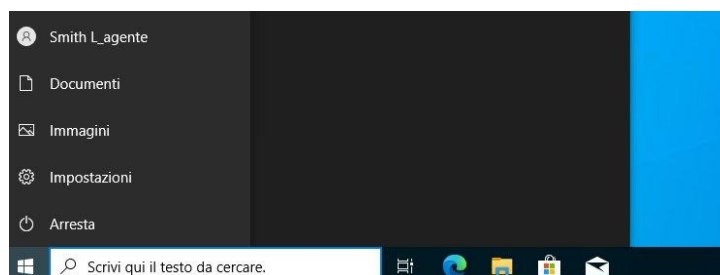


Figura 24 — Login sul client con l'account di dominio Agente Smith

Smith accede senza problemi alla cartella Le_Macchine, sulla quale il suo gruppo dispone del controllo completo, visualizzandone tutti i file.

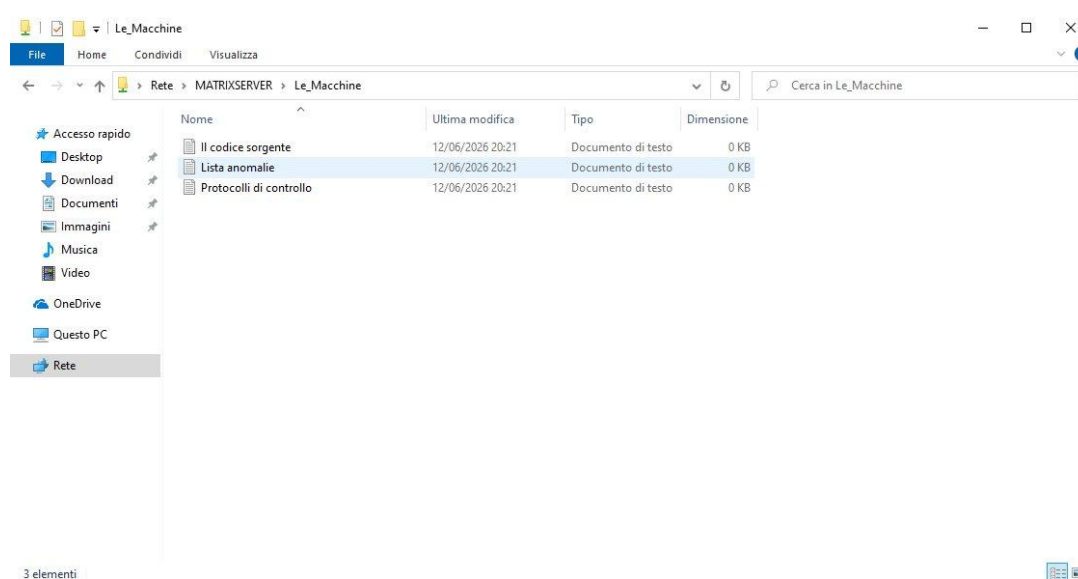


Figura 25 — Smith accede con successo alla cartella Le_Macchine (Full Control)

Quando però Smith tenta di aprire la cartella La_Resistenza, l'accesso viene negato esattamente come avvenuto in precedenza per Neo: nessun agente delle Macchine può leggere i documenti della Resistenza. Le due prove incrociate confermano che il modello di autorizzazione è simmetrico e robusto.

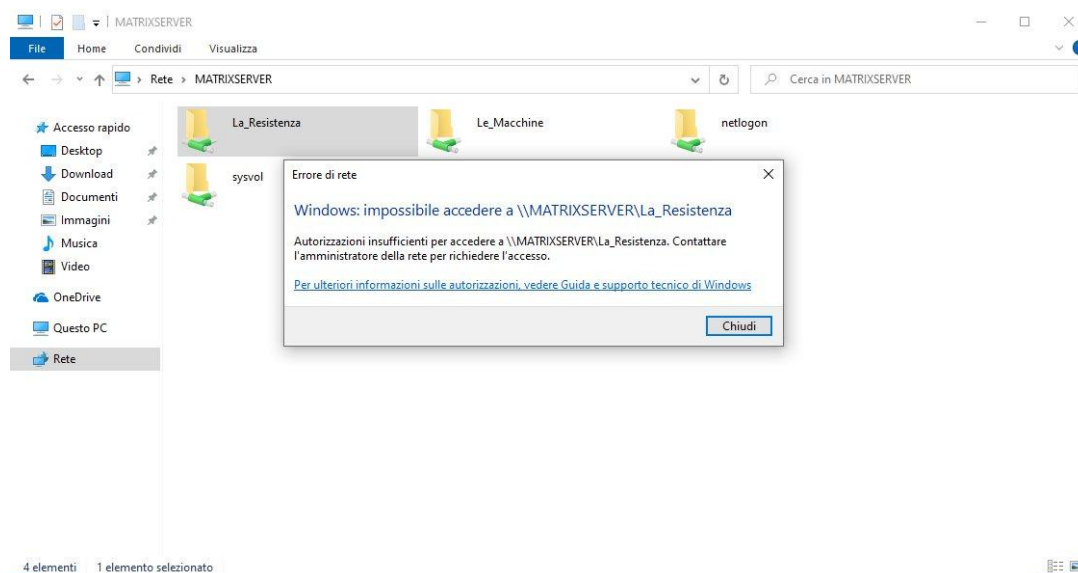


Figura 26 — Accesso negato: Smith non può aprire la cartella La_Resistenza (autorizzazioni insufficienti)

9. Conclusioni

L'esercizio ha permesso di ricostruire da zero un'infrastruttura di dominio Active Directory completa e funzionante, partendo dalla configurazione di rete su pfSense e VirtualBox fino alla promozione del Domain Controller, alla creazione di Unità Organizzative, gruppi di sicurezza e utenti, e infine alla verifica pratica del modello di permessi. Tutte le prove di accesso hanno confermato il comportamento atteso: ciascun gruppo accede esclusivamente alla propria risorsa, mentre i tentativi di accesso incrociato vengono correttamente respinti.

Sul piano didattico, l'attività ha consolidato la comprensione di concetti centrali per un futuro SOC Analyst: la gestione centralizzata delle identità, il modello di controllo degli accessi basato sui ruoli, il principio del privilegio minimo e la separazione dei compiti. Questi stessi principi, in un contesto operativo reale, sono ciò che permette di contenere l'impatto di un account compromesso e di limitare i movimenti laterali di un attaccante all'interno di un dominio.

L'ambientazione a tema The Matrix, oltre a rendere l'esercizio personalmente più motivante, si è rivelata un'efficace chiave di lettura: la contrapposizione tra la Resistenza dai privilegi limitati e le Macchine dal controllo totale traduce in immagini memorabili la distinzione tra utenti standard e amministratori, che è il fondamento di qualsiasi politica di sicurezza ben progettata. Come direbbe Morpheus, si tratta di scegliere consapevolmente cosa un soggetto può e non può vedere — ed è esattamente ciò che fa un amministratore di sistema ogni giorno.

Glossario

Termine	Definizione
Active Directory	Servizio di directory Microsoft per la gestione centralizzata di identità e risorse di rete
Domain Controller	Server che ospita Active Directory e gestisce autenticazione e autorizzazione del dominio
Foresta	Contenitore di più alto livello in AD; definisce il confine di sicurezza e può contenere più domini
OU	Organizational Unit — contenitore logico per raggruppare oggetti e delegare amministrazione
Gruppo di sicurezza	Insieme di account a cui assegnare permessi in modo collettivo (modello RBAC)
RBAC	Role-Based Access Control — assegnazione dei permessi in base al ruolo anziché al singolo utente
Privilegio minimo	Principio per cui a ogni soggetto si concedono solo i permessi strettamente necessari
DNS	Domain Name System — servizio che risolve i nomi; in AD localizza i servizi di dominio via record SRV
pfSense	Firewall/router open source basato su FreeBSD usato come gateway della rete interna

Figura 27 — Glossario dei termini tecnici utilizzati nel report